

Manakasina Judicaël — Adjoint, touche-à-tout

Tu es le joker de l'équipe : tu prends les fonctionnalités **difficiles** (relations, rôles, statuts, API, IA), tu es le **garant de la sécurité** et de l'**administration Filament**, tu **débloques** les autres, et tu es **chef par intérim** quand Randy dort (2 h → 5 h 30).

À lire avec : tome 2 (playbook) en entier ; tome 1 chapitres 6, 12, 13, 14, 18, 22.

1. Tes responsabilités

Tu es responsable de	Concrètement
Les fonctionnalités difficiles	Relations entre entités, workflow de statut, rôles, intégrations (API de l'orga, IA), statistiques
La sécurité	Relire chaque PR sous l'angle sécurité, /audit-secu avant chaque déploiement important, les 5 attaques du jury à H+21
L'administration	Ressources Filament propres (formulaires, badges, filtres, actions de modération, widgets de stats)
Le déblocage	Quiconque est bloqué 20 min vient te voir ; tu résous ou tu escalades à Randy
L'intérim	Triage, merges, déploiements de 2 h à 5 h 30

2. Comment tu choisis ton travail

1. Les fonctionnalités de base qui touchent **plusieurs entités** ou **les rôles** sont pour toi.
2. Toute annonce avec le label `sécu` est pour toi par défaut.
3. Entre deux fonctionnalités : relire les PR ouvertes sous l'angle sécurité (10 min), puis prendre la carte P1 la plus haute.

3. Recettes que tu dois maîtriser

Une relation entre deux entités générées (tome 1 §6)

```
// migration
$table->foreignId('zone_id')->nullable()->constrained()->onDelete('nullOnDelete');
// modèle Signalement
public function zone(): BelongsTo { return $this->belongsTo(Zone::class); }
// modèle Zone
public function signalements(): HasMany { return $this->hasMany(Signalement::class); }
// liste : éviter le N+1
Signalement::with(['user', 'zone'])->latest()->paginate(10);
```

Un statut que seul l'admin change (tome 1 §12, §14)

- `statut hors` `#[Fillable]`, valeur par défaut dans la migration (`->default('en_attente')`).

- Dans la Policy : `public function moderate(User $user): bool { return $user->isAdmin(); }`
- Action Filament « Valider » / « Rejeter » avec `->requiresConfirmation()` qui assigne `$record->statut = 'valide'; $record->save();`
- Test : un utilisateur qui envoie `statut=valide` dans le formulaire → le statut reste `en_attente`.

Limiter une action (tome 1 §13)

```
$cle = 'signalement:'.auth()->id();
if (RateLimiter::tooManyAttempts($cle, 10)) {
    $this->addError('titre', 'Trop de demandes. Réessayez dans une minute.');
```

```
    return;
}
```

```
RateLimiter::hit($cle, 60);
```

Appeler l'API de l'orga ou l'IA (tome 1 §18) : un service dans `app/Services/`, configuration dans `config/services.php`, clé dans `.env`, `Cache::remember`, `timeout`, `retry`, et **un repli propre** si le service tombe. Test avec `Http::fake()`.

Statistiques admin : `php artisan make:filament-widget StatsOverview --stats-overview` (tome 1 §20).

4. Relire une PR sous l'angle sécurité (5 min)

- ☐ Routes dans le groupe `auth` de `routes/features.php` (ou page publique décidée)
- ☐ `$this->authorize(...)` au début de **chaque** méthode publique (`mount`, `save`, `delete`, `actions`)
- ☐ `#[Locked]` sur l'enregistrement du composant
- ☐ Aucun champ réservé (`user_id`, `role`, `statut`) dans `#[Fillable]`
- ☐ `rules()` complet, `Rule::in` pour les listes, `max:` sur les textes
- ☐ Aucun `{!! !!}`, aucun `innerHTML` avec une donnée utilisateur
- ☐ Aucune donnée d'un autre utilisateur exposée (e-mail, téléphone) sans règle
- ☐ Un test « autre utilisateur → 403 »

Un point manquant = commentaire sur la PR + prévenir Randy. **Pas de merge sans ces cases.**

5. Les 5 attaques du jury (à H+21, sur l'URL en ligne)

1. **Changer l'ID** dans une URL d'édition avec le compte d'un autre → 403/404.
2. **Appeler une action Livewire** à la main (outils du navigateur) sur un élément d'un autre → 403.
3. **Ajouter un champ** (`role=admin`, `user_id=1`, `statut=valide`) à une requête → ignoré.
4. **Ouvrir /admin** avec un compte user → 403.
5. **Injecter** `<script>alert(1)</script>` et `<img src=x onerror=alert(1)>` dans chaque champ texte → affiché comme du texte.

Plus : 6 mauvais mots de passe sur `/login` → blocage ; `APP_DEBUG` à `false` (une URL inexistante affiche une page 404 propre, sans trace).

```
grep -E '^(APP_ENV|APP_DEBUG)= ' ~/webcup-2026/.env      # production / false
curl -sI https://virtualvisionsy.madagascar.webcup.hodi.cloud | grep -iE 'x-frame|x-
content|strict-transport'
```

6. Chef par intérim (2 h → 5 h 30)

- Passation de Randy à 2 h (5 min) : déployé, en PR, annonces, sessions cloud, point d'attention.
- Tu tries les annonces (playbook §6), tu merges, tu déploies (`bash ~/webcup-2026/deploy.sh`), tu préviens Njaraniaina (à partir de 4 h).
- Tu ne lances **pas** de chantier risqué (migration lourde, refonte) sans nécessité.
- À 5 h 30, passation à Randy. Le gel à 6 h est le sien.

7. Ta journée

Heure	Toi
9 h → 15 h	Fonctionnalités de base difficiles, relecture sécurité des PR, ressources Filament
15 h → 22 h 30	Progressives difficiles (sécu , intégrations, statuts)
22 h 30 → 2 h	Dormir
2 h → 5 h 30	Chef par intérim
6 h → 8 h	Les 5 attaques du jury + <code>/audit-secu</code> , corrections critiques
8 h 30	Test complet en ligne après le dernier déploiement
Dimanche	Relire le récap et le formulaire avant envoi

8. Préparation (avant samedi)

Voir tes issues `prépa` : installation, première PR, options du générateur, OpenRouter, e-mail sur le serveur, simulation de jeudi.